CYBERNAUT · PROJECT REQUIREMENTS / ML-07

PhishShift Message Risk Scanner

Software Requirements Specification — Student Edition

Project Code: ML-07 | Focus: Cybersecurity NLP + Robustness | Level: Intermediate | Prototype duration: 4 weeks

1. Purpose and problem statement

This educational triage tool evaluates controlled email/SMS training text for suspicious cues. The question is whether a model can recognize unfamiliar phishing wording and urgency/link cues while avoiding false alarms on legitimate messages about passwords, payroll, and other routine work.

2. Intended users and outputs

Primary user: a helpdesk/security-awareness trainee. Input: plain-text simulated message. Output: estimated phishing probability, one of three decisions (high risk, lower estimated risk, or abstain/manual review), matched risk-cue explanation, and a safety disclaimer.

3. Scope and exclusions

In scope: synthetic message data, data validation, duplicate removal, campaign-separated evaluation, rule baseline, TF-IDF linear model, a third model, error analysis, robustness perturbations, and a small local web interface. Excluded: opening links, fetching remote pages, running attachments, collecting live secrets, scanning real mailboxes, or guaranteeing safety.

4. Data schema

Required fields: message_id, channel, subject_or_title, body_text, sanitized_url_features, sender_domain_type, label, campaign_group, collected_date. This package includes 720 locally authored synthetic records before deduplication, plus topic and source_type fields. No live URL or attachment is included.

5. Functional requirements

FR-01: normalize and remove exact/near-duplicate templates before splitting. FR-02: compare rules, TF-IDF + Logistic Regression, and TF-IDF + Random Forest. FR-03: hold out entire campaign groups. FR-04: abstain for probability between 0.40 and 0.60 and show safe risk cues. FR-05: report false-positive rate and perturbation robustness.

6. Non-functional requirements

NFR-01: no suspicious content is fetched, clicked, or executed. NFR-02: no real credentials, mailbox dumps, or personal information. NFR-03: state that results are decision support, not a guarantee of safety. Inputs are limited to 10,000 characters and blank input is rejected.

7. Acceptance tests

AT-01: a legitimate password-reset/urgent message is scanned and false-positive impact is evaluated. AT-02: unfamiliar phishing wording is tested on a campaign excluded from training. AT-03: punctuation/defanged-link wording is varied and probability changes are logged. CP-5: eight harmless simulated messages with controlled text perturbations are included in the robustness log.

8. Limitations and evidence

Synthetic-only data may not represent real attacker language or the full diversity of legitimate messages. Probability is not necessarily calibrated. Mentor-supplied unseen data must be evaluated separately and documented. See README.md, SOURCE_MANIFEST.md, train_model.py, outputs/, tests/, and docs/THREAT_MODEL.md.